

ClarityGRC

AI Governance & Compliance Assessment Report

Assessment Date: July 01, 2026

System Type: Medical

Description: AI system that analyzes patient blood test results and flags anomalies for review by doctors in a large hospital network in France

EU AI Act	Risk Level	Risk Score	DPIA Required
HIGH RISK	HIGH	75/100	Yes

EU AI Act Classification

This AI system is classified as high risk under the EU AI Act. It is legal but subject to strict obligations before and during deployment.

- Mandatory conformity assessment before deployment
- Registration in the EU database of high-risk AI systems
- Comprehensive technical documentation required
- Human oversight mechanisms must be in place
- Ongoing monitoring and incident reporting required
- Transparency obligations to affected individuals

GDPR Obligations

- Establish a lawful basis for processing personal data (consent, contract, or legitimate interest)
- Provide a clear and accessible privacy notice to all affected individuals
- Implement data minimization — only collect what is strictly necessary
- Define and enforce data retention periods — do not keep data longer than needed
- Obtain explicit consent for processing special category data (biometric or health data)
- Appoint a Data Protection Officer (DPO) — mandatory for large scale processing of sensitive data
- Conduct a Data Protection Impact Assessment (DPIA) before processing begins
- Inform individuals when automated decision-making is being used
- Provide individuals the right to request human review of automated decisions
- Explain the logic behind automated decisions when requested
- Conduct a DPIA specifically for the automated decision-making process
- Apply enhanced safeguards for vulnerable or at-risk user groups
- Ensure consent mechanisms are appropriate for vulnerable populations

- Respect individual rights: access, rectification, erasure, portability, and objection

Relevant Articles: Art. 5 — Principles of processing | Art. 6 — Lawful basis for processing | Art. 13/14 — Transparency and privacy notice | Art. 9 — Special category data | Art. 35 — Data Protection Impact Assessment | Art. 37 — Appointment of DPO | Art. 22 — Automated individual decision-making | Art. 9 — Enhanced protection for vulnerable groups | Art. 15-21 — Individual rights

Risk Assessment

Your system presents high risk. Immediate action is required. Prioritize implementing controls and conduct a full DPIA.

- +10 — processes personal data
- +20 — processes sensitive data (biometric or health)
- +35 — decision impact is critical
- +15 — system makes automated decisions
- +15 — system affects vulnerable users or children
- 10 — existing security policy in place
- 10 — Data Protection Officer appointed

ISO 27001 Recommended Controls

Control	Name	Priority
A.12	Operations Security	Critical
A.14	System Acquisition and Development	Critical
A.16	Incident Management	Critical
A.5	Information Security Policies	High
A.8	Asset Management	High
A.9	Access Control	High
A.18	Compliance	High
A.10	Cryptography	High
A.14.2	Security in Development	High
A.17	Business Continuity	Medium
A.15	Supplier Relationships	Medium

NIS2 Directive

Classification: ESSENTIAL ENTITY

Your organization qualifies as an ESSENTIAL ENTITY under NIS2. This directive became enforceable across EU member states in October 2024 and requires immediate compliance action.

Sector Note: Healthcare entities must pay particular attention to incident reporting and supply chain security for medical devices and systems.

- Implement a comprehensive cybersecurity risk management framework
- Establish and maintain an incident response plan
- Report significant cybersecurity incidents to national authority within 24 hours (early warning) and 72 hours (full report)
- Conduct regular cybersecurity risk assessments
- Implement supply chain security measures for all critical vendors
- Ensure business continuity and crisis management capabilities
- Implement multi-factor authentication and encryption across systems
- Conduct regular cybersecurity training for all staff
- Designate a responsible person or team for NIS2 compliance
- Register with your national NIS2 competent authority

Penalties: Essential entities: up to €10 million or 2% of global annual turnover. Important entities: up to €7 million or 1.4% of global annual turnover.

DORA — Digital Operational Resilience Act

Classification: NOT APPLICABLE

DORA (Digital Operational Resilience Act) applies exclusively to financial sector entities. Your organization is not subject to DORA obligations.

ISO 42001 — AI Management System

ISO 42001 is the international standard for AI Management Systems (AIMS). Published in 2023, it provides a framework for responsible development and use of AI systems.

Control	Name	Priority
6.2	AI Objectives and Planning	Critical
8.3	AI System Design and Development Controls	Critical
8.4	Data Governance for AI	Critical
8.6	Human Oversight of AI Systems	Critical
8.5	Transparency and Explainability	Critical
8.8	Bias and Fairness Assessment	Critical
4.1	Understanding the Organization and its Context	High
5.1	Leadership and AI Policy	High
6.1	AI Risk Assessment	High
8.2	AI System Impact Assessment	High

9.1	Monitoring and Measurement	High
8.7	Accountability Framework	High
8.9	Affected Parties Communication	High
10.1	Continual Improvement	Medium
7.3	AI Awareness and Training	Medium

AI Governance Consultant Summary

Your AI system has been classified as high-risk under the EU AI Act, with a risk score of 75. This means you must take immediate action to ensure compliance with GDPR obligations and implement recommended ISO 27001 controls. You need to establish a lawful basis for processing personal data, provide clear privacy notices, and implement data minimization and retention policies. You must also conduct a Data Protection Impact Assessment and appoint a Data Protection Officer. If you don't comply, you risk facing significant fines and reputational damage. To avoid this, prioritize these recommendations and take swift action to address the identified risks and implement the necessary controls to ensure the secure and responsible operation of your AI system.

Disclaimer: This report was generated automatically by ClarityGRC for educational and awareness purposes. It does not constitute legal advice. Please consult a qualified GRC professional or legal counsel for formal compliance assessments.